

07 보안·권한·감사 가이드

인증·Session·권한·승인·감사·Secret 을 CPF 공개 계약으로 적용하는 실무 매뉴얼

기준 Source: master bd5fcd7707cfbba366071e7e4556c5cbb9b974bc · 2026-08-15

1. 보안 구성 선택

필요	선택 구성	적용 기준
보호 REST API	`secure-api`	Resource Server 기반 보호 API
사용자 인증	OIDC Provider	외부 Identity Provider 연계
서버 Session	JDBC / Valkey Session	Browser/BFF 상태 유지
서비스 간 신원	Service Identity	Runtime 간 인증
기능 권한	`@CpfPermission`	Authority 기반 접근 제어
위험 조치 승인	`@CpfApprovalRequired`	승인 후 실행
변경 감사	`@CpfAudit`	행위·결과·사유 기록

2. 권한

Annotation 옵션	의미	예
`value`	필요 Authority 목록	`{"MEMBER_READ"}`
`all=true`	모든 Authority 필요	복수 권한 AND
`all=false`	하나 이상 Authority	복수 권한 OR

```
@CpfPermission({"MEMBER_WRITE"})
public void changeMember(...) { ... }
```

3. 승인

옵션	역할	기본
`action`	승인 대상 업무 ID	필수
`approvals`	필요 승인 수	1
`reasonRequired`	사유 필수	true
`approvalIdParameter`	승인 ID Parameter 명	approvalId
`reasonParameter`	사유 Parameter 명	reason

4. 감사

옵션	역할	기준
`action`	감사 행위 ID	안정된 업무 ID
`reasonRequired`	사유 요구	위험 변경 작업
`includeSafeResultSummary`	안전한 결과 요약	민감정보 제외

Logging 과 **Audit** 구분 **Logging** 은 진단/관측을 위한 기록이고 **Audit** 은 누가 어떤 변경을 어떤 사유로 수행했는지 남기는 불변 운영 기록입니다.

5. Session·Service Identity

영역	선택	확인
Browser/BFF Session	JDBC / Valkey	TTL·강제 Logout·다중 Instance
OIDC	OIDC Provider	Issuer·Audience·Key Rotation
Service Identity	서비스 신원 계약	호출자·대상·Credential Rotation

6. Secret·민감정보

- DB Password·Token·Private Key·Certificate Secret 은 Source 에 저장하지 않습니다.
- Secret 은 환경 변수 또는 Secret Manager 등 외부 주입을 사용합니다.
- Log·화면·Audit Summary 에는 Password·Token·전문 원문·PII 를 마스킹합니다.
- Application 계정과 Provision/Migration 계정의 권한을 분리합니다.

7. 오류 처리

상태	의미	확인
401	인증 실패/없음	Token·Session·Client
403	권한 부족	Role·Authority·Permission
409	승인/상태 충돌 가능	approvalId·Version·현재 상태
429	요청 제한	Rate/Concurrency 정책
503	Identity/Downstream 사용 불가	Health·Circuit·Provider 상태

8. 코드·테스트 참조

대상	위치
Security Annotation	`cpf-starters/security/src/main/java/com/cpf/security/api/annotation/**`
Audit	`cpf-starters/platform-operations/**/CpfAudit.java`
Session Provider	`cpf-starters/security/**`
Education	`cpf-education/**`
ADM/BZA 권한	`cpf-admin/**`, `cpf-biz-admin/**`